# 畢業專題 文獻探討

## Agentic AI 安全

Syu

2026 年 10 月 19 日

# 目錄


1. 回顧
2. 行動前授權
3. MCP 安全框架
4. 學習式能力治理
5. 系統層級代理治理

# 回顧：Agentic AI 安全

1. **Agentic AI Security (2510.23883)**
   - 威脅：prompt injection、工具濫用、MCP 與多代理攻擊。
   - 防禦：sandboxing、存取控制與執行期監控。
2. **Agentic AI and Cybersecurity (2601.05293)**
   - 雙用途代理：自主防禦與自動化漏洞利用。
3. **Agent-SafetyBench (2412.14470)**
   - 針對代理行為與攻擊情境的互動式安全性評估。

**重點結論**

代理安全需要超越模型層級對齊、且可強制執行的控制機制。

# 回顧：Streamo

## 串流影片指令微調

- **問題**：離線影片模型與多階段（multi-pass）流程會增加回應延遲。
- **方法**：單次（one-pass）推論，搭配三種狀態 token：
  - `<Silence>`：持續處理影格。
  - `<Standby>`：等待進行中的事件。
  - `<Response>`：產生回答。
- **訓練**：Streamo-Instruct-465K 與 focal-weighted LM loss。

## 重點結論

Streamo 著重即時互動；Video Streaming Thinking 則強調較長期的推理。

# 回顧：StreamEQA

## 串流具身問答

- **目標：**在無法取得未來影格的情況下，評估線上第一人稱影片理解能力。
- **具身維度：**
  - 感知、互動、規劃。
- **串流維度：**
  - 回溯推理、即時理解、前向預測。
- **方法：**擷取影片 metadata、建構問答配對，並對多模態模型進行基準測試。

## 關聯

即時的代理決策在執行外部動作前，同樣需要安全檢查。

# 行動前授權 (arXiv 2603.20953)

**Before the Tool Call: Deterministic Pre-Action Authorization for Autonomous AI Agents**

Uchi Uchibeke
APort Technologies Inc., Toronto, Canada

## 摘要

自主代理可呼叫強大的工具，卻缺乏標準化、確定性的授權邊界。

- **OAP**：在執行前攔截每一次工具呼叫。
- 依據代理身分、能力與呼叫參數評估宣告式政策。
- 產生經密碼學簽章的稽核紀錄。
- **結果**：授權延遲中位數 53 ms；在 879 次限制性政策攻擊嘗試中，成功攻擊為 0 次。

arXiv: 2603.20953v1

# 授權模型 (arXiv 2603.20953)

## 確定性授權

$$\text{authorize}(\mathsf{T}, \mathsf{P}, \Pi) \longrightarrow (\mathsf{D}, \mathsf{L})$$

- T：工具呼叫與參數；P：代理護照（passport）與能力。
- $\Pi$：宣告式政策；L：簽章稽核日誌。
- $\mathsf{D} \in \{\text{ALLOW}, \text{DENY}, \text{ESCALATE}\}$.

1. 驗證身分、能力與政策限制。
2. 拒絕未授權的參數或保證等級不足的請求。
3. 在執行前做出決策並記錄結果。

## 邊界

確定性授權是對 sandbox 隔離的補充，而非取代。

arXiv: 2603.20953v1

# 對抗式評估 (arXiv 2603.20953)

## 結果

- **53 ms** 決策延遲中位數 ($N = 1{,}000$)。
- **74.6%** 寬鬆政策下的模型層級社交工程成功率。
- **0/879** 限制性 OAP 政策下的攻擊成功次數。

## 限制

- 靜態政策設計；跨代理委派尚未完全形式化。
- 個別獲授權的動作仍可能組合成不安全的工作流程。
- 人工核准（ESCALATE）在參考系統中尚未實作。

arXiv: 2603.20953v1

# MCP 威脅建模 (arXiv 2604.05969)

**A Formal Security Framework for MCP-Based AI Agents: Threat Taxonomy, Verification Models, and Defense Mechanisms**

Nirajan Acharya (University of the Cumberlands)
Gaurav Kumar Gupta (Youngstown State University)

## 摘要

MCP 工具生態系引入新的信任邊界與零散的安全控制。

- **分類**：7 類威脅、23 種攻擊向量、4 個攻擊面。
- **方法**：標記轉移系統與形式化安全性質。
- **分析**：比較 12 種既有防禦機制。
- **提案**：四層縱深防禦架構，理論涵蓋率 91%。

arXiv: 2604.05969v1

# 形式化驗證模型 (arXiv 2604.05969)

## MCP 模型與標記轉移系統

$$\mathsf{M} = (\mathsf{A}, \mathsf{S}, \mathsf{T}, \mathsf{R}, \mathsf{C}, \ell), \quad \mathsf{LTS} = (\Sigma, \Sigma_0, \Lambda, \rightarrow)$$

A：代理；S：伺服器；T：工具；R：資源；
C：連線；$\ell$：安全標籤；$\Sigma$：系統狀態。

## 已驗證性質

- **工具完整性**：防止核准後的工具被修改。
- **資料限縮**：限制跨邊界的資訊流。
- **權限有界性**：強制執行能力上限。
- **情境隔離**：阻擋未經授權的情境共享。

arXiv: 2604.05969v1

# 縱深防禦 (arXiv 2604.05969)

## 建議的防禦層

1. 基於能力的存取控制。
2. 密碼學工具證明（attestation）。
3. 資訊流追蹤。
4. 執行期政策強制。

## 涵蓋率分析

- 單一防禦機制涵蓋的已識別威脅皆不超過 **34%**。
- 整合式架構：**理論威脅涵蓋率 91%**。

**註：**涵蓋率為理論值，並非實測的攔截率。

arXiv: 2604.05969v1

# 自適應最小權限 (arXiv 2604.11839)

**Beyond Static Sandboxing: Learned Capability Governance for Autonomous AI Agents**
Bronislav Sidik, Lior Rokach
Ben-Gurion University of the Negev, Institute for Applied AI Research

## 摘要

即使是簡單任務，代理執行環境也暴露過多工具，擴大了攻擊面。

- **AgentWarden**：任務感知的能力範圍界定與執行前安全路由。
- **學習**：PPO 利用 session 稽核資料最佳化工具可用性。
- **指標**：

$$\text{SER} = \frac{|\text{已呼叫工具}|}{|\text{已暴露工具}|}$$

- **結果**：摘要任務中暴露的工具減少 73%。

arXiv: 2604.11839v2

# MDP 與 PPO 策略 (arXiv 2604.11839)

## 馬可夫決策過程

- **狀態**：任務類別與正規化信任等級（7 維）。
- **動作**：二元工具存取遮罩，$a \in \{0,1\}^{17}$。
- **策略**：PPO，搭配兩層 MLP（每層 64 單元）。

$$R(s,a) = \alpha U_{\text{accuracy}} - \beta C_{\text{economy}} - \gamma P_{\text{safety}}$$

$(\alpha, \beta, \gamma) = (1, 0.3, 5)$.

## 執行期強制

Capability Governor 限制可見工具；Safety Router 檢查每一個提出的呼叫。

arXiv: 2604.11839v2

# 評估與失效模式 (arXiv 2604.11839)

## OpenClaw 實驗

- **500 項任務**：400 項良性、100 項對抗性。
- **73%** 摘要任務中暴露工具的減少幅度。
- **26.2%** 的 447 次被攔截工具呼叫遭到阻擋。
- **92%** 的對抗任務被整合堆疊成功化解。

## 主要限制

- PPO 在實際評估中有時會退化為單一工具策略。
- 系統隨後退回使用基於 YAML 的政策。
- Safety Router 的訓練資料量小且不平衡。

arXiv: 2604.11839v2

# 跨代理行動治理 (arXiv 2609.00015)

**OpenAgentFlow: Enabling System-Wide Safety Boundaries for Heterogeneous AI Agent Fleets**

Dongsheng Chen (Southern University of Science and Technology)
Xiangyu Zhao (City University of Hong Kong)
Xin Yao (Lingnan University); Xuetao Wei (Southern University of Science and Technology)

## 摘要

個別有效的動作，跨多個代理與應用程式後可能構成不安全的工作流程。

- 將 GUI、API 與工具動作正規化為共用的 **AgentEvents**。
- 在共用的 **行動提交邊界（action-commit boundary）**強制執行政策。
- 在個別代理之外維護來源（provenance）、session 狀態與稽核紀錄。
- **結果：**在 1,220 個 AgentDojo-Traj 案例上達 97.62% 準確率。

arXiv: 2609.00015v2

# 共用政策強制執行 (arXiv 2609.00015)

## 控制平面 / 行動平面

- **控制平面：**政策、來源、session 狀態、稽核紀錄。
- **行動平面：**共用的政策執行點（PEP）。
- **行動提交邊界：**在產生副作用之前檢查動作。

## 政策決策階段

1. T1：結構化政策規則。
2. T2：Payload 與來源檢查。
3. T3：規則不足時進行語意評估。
4. T4：最終裁決與升級處理。

arXiv: 2609.00015v2

# 系統評估 (arXiv 2609.00015)

## 結果

- **300 案例受控測試集**：準確率 94.00%；攻擊攔截率 95.35%。
- **1,220 案例 AgentDojo-Traj**：準確率 97.62%。
  - 不安全動作召回率 96.59%。
  - 對安全動作的誤介入率 1.96%。
- 於 Android 動作路徑上展示政策更新與強制執行。

## 主要挑戰

有效的防護取決於完整的事件擷取與準確的跨步驟來源追蹤。

arXiv: 2609.00015v2